PASTA THREAT MODEL WORKSHEET

Mobile E-Commerce Sneaker Application

Framework: PASTA (Stages I–VII)
Role: Cybersecurity Analyst
Application: Sneaker Marketplace App

Stage I: Define Business Objectives	• **Protect Customer Data & Privacy:** Safeguard user credentials and payment information to maintain consumer trust and avoid regulatory penalties. • **Seamless & Secure Commerce:** Ensure smooth, resilient buyer-seller transactions with multiple checkout options without operational downtime. • **Reliable Communication:** Provide protected in-app messaging and transparent vendor rating systems to avoid fraudulent interactions.
Stage II: Define Technical Scope	I prioritize evaluating **Structured Query Language (SQL)** first because the relational database serves as the centralized repository storing customer profiles, financial transaction histories, and inventory data. Any vulnerability in SQL logic exposes the organization directly to injection attacks (SQLi), allowing malicious actors to bypass authentication layers, extract sensitive database assets, and tamper with sales records.
Stage III: Decompose the Application	• **Search & Catalog Browsing:** Client queries pass through API gateways to the relational SQL database to retrieve inventory and pricing. • **Payment & Session Handling:** Sensitive checkout workflows transmit through third-party APIs secured via PKI/TLS, storing password digests via SHA-256.
Stage IV: Threat Analysis	• **SQL Injection (SQLi) Attacks:** Threat actors submitting malicious database payloads through unvalidated search queries or login fields. • **API Interception & Abuse:** Adversaries exploiting unencrypted communications or broken endpoint validation to compromise session tokens and credit card data.
Stage V: Vulnerability Analysis	• **Improper Input Validation:** Insufficient sanitization of user-supplied parameters before database query execution. • **Cryptographic & Key Management Flaws:** Insecure encryption key storage or legacy TLS ciphers exposing financial data during transit.
Stage VI: Attack Modeling	**Objective: Exfiltrate Payment Data & User Accounts** • *Attack Path 1:* Exploit search bar input field → Execute SQL Injection → Dump user credential tables. • *Attack Path 2:* Compromise employee account credentials → Abuse internal API endpoints → Intercept live transaction streams.
Stage VII: Risk & Impact Analysis	• **Parameterized Queries:** Enforce prepared statements to completely eliminate SQL Injection threats. • **End-to-End Encryption (AES & TLS):** Protect stored sensitive assets and active network communications. • **Multi-Factor Authentication (MFA):** Mandate MFA for account access to nullify credential stuffing and stolen passwords. • **Principle of Least Privilege & AAA:** Restrict database service accounts and API permissions strictly to minimum required roles.